PLAYBOOK DE RESPUESTA

PB-07 | Escaneo de puertos y reconocimiento

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Diferenciar barridos hacia API pública o servidores de un ejercicio autorizado.

02. Disparador, fuente y umbral

NGFW/IPS o Wazuh: muchas conexiones denegadas desde la misma IP. Umbral propuesto: ≥20 puertos distintos en 60 s o ≥100 conexiones denegadas/5 min.

03. Severidad inicial y promoción

Baja si bloqueo externo aislado; Media si repetido; Alta cuando proviene de VLAN interna o precede explotación del API.

04. Triage: validación paso a paso

1. Identificar IP fuente, destino, puertos y ventana del barrido.
2. Confirmar si la fuente es del auditor o escáner autorizado.
3. Verificar si hubo conexiones aceptadas o intentos de explotación.
4. Cruzar con alertas web, VPN y accesos de bastión.
5. Evaluar exposición del servicio y criticidad de API de pagos.

05. Contención autorizada a N1

- Bloqueo temporal de IP externa maliciosa y registro de reversión.
- Solicitar análisis de origen a TI ante IP interna.

06. Acciones no autorizadas a N1

- No escanear de vuelta al origen.
- No aplicar bloqueos generalizados a rangos de proveedores de nube.

07. Evidencia mínima preservada

- Flujos / bloqueos NGFW, ventana, IP, puertos, permisos de regla y correlación.

08. Escalamiento obligatorio a N2

Origen interno, intento de explotación, API comprometida o servidor crítico como objetivo.

09. Criterios de cierre técnico

Reconocimiento externo bloqueado sin explotación; propuesta de endurecimiento de puertos.

10. Mejora continua

Ajustar umbral para excluir monitoreo legítimo sin crear puntos ciegos.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-07 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.